CORVANE SYSTEMS

Document ID	SEC-005
Version	2.3
Effective date	1 January 2026
Owner	Chief Information Security Officer (CISO)
Applies to	All Corvane user, administrator and service accounts

Password and MFA Standard

1. Why this matters

Stolen or guessed passwords are still one of the most common ways attackers get into companies. This standard sets simple rules that make Corvane accounts much harder to take over. The rules follow current industry guidance: long passwords, no forced periodic changes, and multi-factor authentication (MFA) everywhere.

2. Password requirements

Account type	Minimum length	Other rules
Standard user account	14 characters	Must not appear in the list of known breached passwords.
Privileged / administrator account	20 characters	Separate from your standard account; used only for admin tasks.
Service account (used by applications)	32 random characters	Stored only in Corvane Vault; rotated every 90 days.
Device PIN (Windows Hello, phone)	6 digits	No simple sequences such as 123456 or 111111.

There are **no complexity rules** (such as "one capital letter, one symbol"). Length matters more than complexity. We recommend a **passphrase** of four or more random words, for example "copper lantern violet harbour".

You do not have to change your password on a schedule. You **must** change it immediately if:

- you think someone else knows it or has seen you type it;
- you entered it on a website that might be fake;
- the Security Desk tells you that your password appeared in a breach.

3. Things you must never do

- Reuse your Corvane password on any other website or service, including other work tools.
- Share your password with anyone. **Corvane IT and the Security Desk will never ask for your password**, by email, chat or phone. Anyone who asks is an attacker.

- Write passwords on paper, in notes apps, in spreadsheets or in code.
- Store passwords in your browser's built-in password manager for Corvane accounts.
- Use a Corvane password that contains your name, your username, "Corvane" or the current year.

4. Password manager

All employees receive **Corvane Vault**, the approved password manager. Use it for every work password that is not covered by single sign-on (SSO). The Vault master password must be at least 16 characters and must not be used anywhere else. Team passwords are shared through shared Vault folders, never by email or chat.

5. Multi-factor authentication (MFA)

MFA is required for:

- all access to Corvane email, chat and SSO applications;
- all remote access (VPN and web apps from outside the office);
- all administrator and privileged accounts, with no exceptions;
- Corvane Vault.

Approved MFA methods (strongest first)

1. **FIDO2 security key** (hardware key). Required for administrators and for the Finance, HR and Security teams.
2. **Authenticator app with number matching** (Corvane Authenticator). Default for all other employees.
3. **SMS code**. Allowed only as a temporary fallback, for at most **30 days**, for example after losing your phone. SMS codes can be intercepted, so the Service Desk will ask you to re-register an app as soon as possible.

MFA fatigue attacks

Attackers who already know a password sometimes send many MFA prompts, hoping the user will approve one to make them stop. **Never approve an MFA prompt you did not start.** If you receive an unexpected prompt:

1. deny it;
2. change your password immediately, because the prompt means your password is probably known;
3. report it to the Security Desk (ext. 4444).

6. Account lockout

After **10 failed login attempts**, an account is locked for **15 minutes**. Repeated lockouts are reported to the Security team automatically. If you are locked out and need access urgently, call the IT Service Desk (ext. 2222); they will verify your identity with a video call and your Corvane badge before unlocking the account.

7. Privileged accounts

Administrators use a separate privileged account (named "adm-" followed by the username). Privileged accounts:

- are never used for email, browsing or chat;
- are reviewed every **quarter** by the system owner;
- are disabled after **30 days** without use;
- are removed on the same day that the person changes role or leaves Corvane.

8. Lost or compromised MFA devices

If you lose a phone or security key used for MFA, report it to the Security Desk within **1 hour**. The device is removed from your account, and you will register a new one with the IT Service Desk after an identity check.

9. Compliance

Systems that cannot enforce this standard need a documented exception approved by the CISO, valid for at most 12 months. Breaches of this standard may lead to disciplinary action.

Fictional sample document created for the KnowGauge demo. Corvane Systems is not a real company, and this document is not legal or HR advice.